

## **(d) Mapeo detallado de preguntas a requisitos normativos (NIS2, CRA y buenas prácticas CVSS)**

| Bloque | Pregunta | Tema principal                                   | Referencia CVSS / Buenas prácticas                                                                          | Referencia NIS2 / CRA / otros                                                                                                                     |
|--------|----------|--------------------------------------------------|-------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| 2      | 2.1      | Proceso formal de gestión de vulnerabilidades    | CVSS v4.0 User Guide: necesidad de procesos para enriquecer Base con Threat y Environmental[web:17][web:63] | NIS2: medidas de gestión de riesgos, vulnerability handling[web:56][web:61]; CRA: procesos documentados de vulnerability handling[web:57][web:62] |
| 2      | 2.2      | Frecuencia de identificación de vulnerabilidades | Buenas prácticas de gestión de vulnerabilidades (escaneos regulares)[web:63]                                | NIS2: evaluación continua de riesgos y vulnerabilidades[web:61][web:64]                                                                           |
| 2      | 2.3      | Fuentes de información de vulnerabilidades       | Uso de bases como NVD y CERT para métricas CVSS[web:53][web:63]                                             | NIS2: intercambio de información y bases europeas de vulnerabilidades[web:56]                                                                     |
| 3      | 3.1–3.4  | Uso de CVSS y responsabilidad                    | CVSS v4.0 Specification y User Guide: uso correcto de Base/Threat/Environmental[web:16][web:17][web:55]     | CRA: necesidad de evaluar severidad de vulnerabilidades[web:57][web:62]                                                                           |
| 4      | 4.2–4.4  | Adopción de CVSS 4.0 y métricas Base             | Estructura y aplicación de métricas Base en CVSS 4.0[web:16][web:55][web:58]                                | Apoya cumplimiento general NIS2/CRA al mejorar clasificación de severidad                                                                         |
| 5      | 5.1–5.3  | Threat / explotación activa                      | Uso de Threat Metrics para aproximarse al riesgo real[web:16][web:17][web:58]                               | NIS2 y CRA: reporte rápido y tratamiento de vulnerabilidades explotadas activamente[web:56][web:57][web:59]                                       |

|    |           |                                                   |                                                                                                         |                                                                                                                                    |
|----|-----------|---------------------------------------------------|---------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| 6  | 6.1–6.3   | Métricas Environmental / criticidad               | Ajuste al entorno específico y activos críticos[web:16] [web:17][web:63]                                | NIS2: enfoque basado en riesgo, continuidad, activos críticos[web:61] [web:64]                                                     |
| 7  | 7.1–7.5   | Métricas Supplemental (Automatable, Safety, etc.) | CVSS 4.0 Supplemental metrics: automatización, seguridad física, recuperación[web :16][web:55] [web:58] | CRA: impacto en seguridad de productos y usuarios; NIS2: resiliencia, continuidad[web: 57][web:61]                                 |
| 8  | 8.1–8.4   | Alineamiento con NIS2 y CRA                       | Uso de CVSS como soporte de evidencia y priorización[web: 17][web:63]                                   | NIS2: gestión de vulnerabilidades y reporting[web:56] [web:61]; CRA: vulnerability handling y disclosure[web:57 ][web:59] [web:62] |
| 9  | 9.1–9.3   | Indicadores y reporting                           | User Guide: CVSS-BTE como aproximación a riesgo y métricas asociadas[web:17] [web:58]                   | NIS2: medición de eficacia y reporting a la dirección[web:61] ; CRA: tiempos de respuesta[web:59]                                  |
| 10 | 10.1–10.3 | ROI y percepción de valor                         | Buenas prácticas de gobierno de seguridad: vincular métricas técnicas a negocio[web:58]                 | NIS2: responsabilidad de la dirección y supervisión[web:6 1]                                                                       |
| 11 | 11.1–11.3 | Prioridad estratégica y barreras                  | CVSS 4.0 como marco avanzado que requiere formación, herramientas y gobierno[web:16] [web:58][web:63]   | NIS2/CRA: transición hacia seguridad por diseño y gestión continua de vulnerabilidades[ web:56][web:57]                            |